INDEPENDENT SERVICE AUDITOR'S REPORT (SOC 2 TYPE II)

VANTA SOC 2 COMPLIANCE COLLECTION & TRUST REGISTRY · AICPA AT-C 205

TO: Management of CyberVault Storage Solutions Ltd. & Customer Trust Authorities
AUDIT PERIOD: October 1, 2023 to March 31, 2024
AUDITING FIRM: Deloitte & Touche LLP (Accredited CPA Examination Board)
TRUST SERVICES CRITERIA: Security (Common Criteria CC6.1 - CC7.2), Confidentiality, and Availability
OPINION: UNQUALIFIED (CLEAN) OPINION ? ZERO DEVIATIONS DETECTED

SECTION I. INDEPENDENT AUDITOR'S OPINION
In our opinion, in all material respects, based on the criteria described in CyberVault's assertion:
a. The description fairly presents the cloud storage and data management system as implemented throughout the audit period;
b. The controls stated in the description were suitably designed to provide reasonable assurance that the criteria were achieved;
c. The tested controls operated effectively throughout the period from October 1, 2023 to March 31, 2024 with zero non-conformances.

SECTION II. TEST RESULTS OF RELEVANT SECURITY CONTROLS

1. CONTROL CC6.6 ? CRYPTOGRAPHIC ENCRYPTION AT REST AND IN TRANSIT (RULE-SEC-001)
? Control Specification: Cloud storage volumes and object buckets must enforce AES-256-GCM encryption at rest. Inter-system API telemetry must enforce TLS 1.3 with Perfect Forward Secrecy.
? Auditor Testing Performed: Inspected AWS KMS key configurations, AWS EBS volume attributes, and production TLS ciphersuite handshakes. Sampled 100 production S3 buckets and block storage volumes across US-East and EU-West regions.
? Results of Tests: Operating Effectively. 100% of sampled production volumes verified encrypted with AES-256. Zero unencrypted buckets found.

2. CONTROL CC6.1 ? MULTI-FACTOR AUTHENTICATION FOR ADMINISTRATIVE ACCESS (RULE-SEC-002)
? Control Specification: Mandatory hardware-backed MFA (FIDO2 / YubiKey) required for all cloud management consoles and administrative access.
? Auditor Testing Performed: Inspected Okta identity provider logs and AWS IAM policies for all 42 administrative personnel. Attempted single-factor logins.
? Results of Tests: Operating Effectively. Single-factor access strictly blocked by policy. 100% of privileged sessions required WebAuthn/FIDO2 hardware MFA.

3. CONTROL CC7.2 ? SECURITY INCIDENT TIMELY ESCALATION (RULE-SEC-004 & GDPR ART. 33)
? Control Specification: Security incident response protocol requires formal customer escalation within 72 hours of confirmed detection.
? Auditor Testing Performed: Examined Jira incident response logs for all logged priority security events occurring during the 6-month observation window.
? Results of Tests: Operating Effectively. All logged incidents were resolved within SLA; zero statutory notification delays detected.

4. CONTROL CC6.3 ? SUBPROCESSOR VETTING & REGISTRY (RULE-SEC-006 & GDPR ART. 28)
? Control Specification: Downstream sub-processors must undergo annual SOC 2 / ISO review and execute DPAs prior to receiving data.
? Auditor Testing Performed: Sampled subprocessor vendor registry and verified annual audit review records for all active vendors.
? Results of Tests: Operating Effectively. All active subprocessors maintained current SOC 2 Type II reports and countersigned DPAs.